Heartbleed bug

Example

Heartbleed bug : Issue : The attacker could lie about the size of their data.

- Attacker sends 1 byte of data.
- Attacker claims they sent 64,000 bytes.
- The server, without checking the actual length, would reply with the attacker's 1 byte plus the next 63,999 bytes of whatever was in its private memory.

Definition

Transport Layer Security (TLS) is a cryptographic protocol that provides privacy, data integrity, and authentication for internet communications.

1 – Economy of mechanism

Key idea

"Keep the [security mechanism / implementation] design as simple and small as possible"

Why ?
It needs to be easy to audit and verify.
(operational testing is not appropriate to evaluate security)
[Penetration testing is valuable]

Definition

The "Trusted Computing Base" (TCB)
Every component of the system on which the security policy relies.
Hardware / firmware / software

Key idea

The TCB is trusted to operate correctly for the security policy to hold

Warning

The only proper use of the verb "to trust" in Security Engineering :
"X trusts Y will do Z"

2 – Fail-safe defaults

Key idea

"Base access decisions on permission rather than exclusion" [SS75]

Definition

Ransomware – What is it ?

- A Ransomware denies you access to your own data, most commonly by encrypting your files
- Attacker then demands a ransom payment in exchange for the private key required to decrypt your files

3 – Complete mediation

Key idea

"Every access to every object must be checked for authority" [SS75]

4 – Open design

Key idea

"The design should not be secret" [SS75]

5 – Separation of privilege

Key idea

"No single accident, deception, or breach of trust is sufficient to compromise the protected information" [SS75]

6 – Least privilege

Key idea

"Every program and every user of the system should operate using the least set of privileges necessary to complete the job" [SS75]

7 – Least common mechanism

Key idea

"Minimize the amount of mechanism common to more than one user and depended on by all users" [SS75]

8 – Psychological acceptability

Key idea

"It is essential that the human interface be designed for ease of use, so that users routinely and automatically apply the protection mechanisms correctly" [SS75]

Extra principles from physical security

9 – Work factor

Key idea

"Compare the cost of circumventing the mechanism with the resources of a potential attacker" [SS75]

10 – Compromise recording

Key idea

"Reliably record that a compromise of information has occurred [...] in place of more elaborate mechanisms that completely prevent loss" [SS75]